



2016 中国互联网安全大会
China Internet Security Conference

协同联动 共建安全+命运共同体

云签名服务 —— 连接用户与互联网应用的信任桥梁

林雪焰

副总经理
北京数字认证股份有限公司

无纸化革命对可靠签名的需求



中国互联网安全大会



360互联网安全中心

移动
展业

远程
开户

互联网
金融

电子招
投标

...



无纸化是~~未来~~业务发展的驱动力
可靠电子签名是其中最核心的引擎之一

可靠电子签名是签署合法电子合同必要条件



数据电文、电子签名都可以作为证据使用；
而可靠电子签名才具有手写签名或者盖章的强证据效力。

“可靠的电子签名与手写签名或者盖章具有同等的法律效力”

——《电子签名法》第十四条

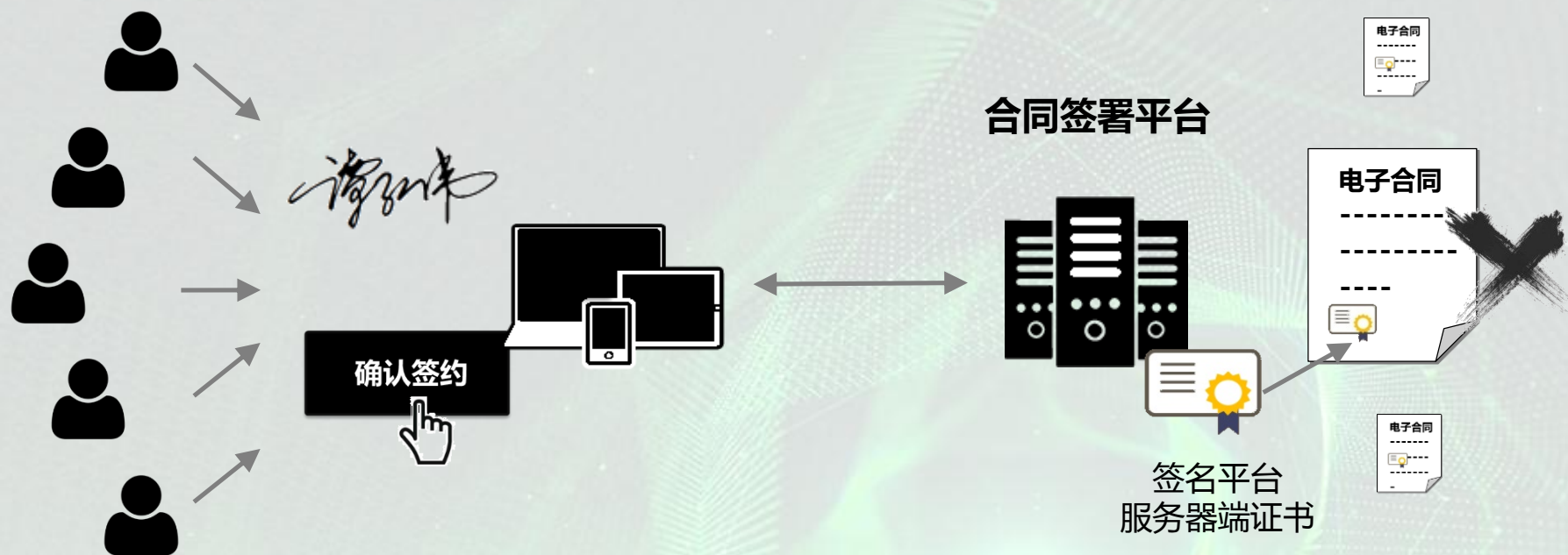
PKI数字签名是目前实现可靠电子签名唯一技术



签名人私钥为签名人**专有和控制**是可靠电子签名的要点

《电子签名法》要求	PKI数字签名方案实现
第十三条 电子签名同时符合下列条件的，视为可靠的电子签名：	
（一）电子签名制作数据用于电子签名时，属于电子签名人 专有 ；	CA机构鉴证签名人身份，为签名人颁发对应身份信息的数字证书，证书私钥作为电子签名制作数据
（二）签署时电子签名制作数据仅由电子签名人 控制 ；	证书私钥在签名人设备中，仅有签名人持有和控制，私钥安全存储
（三）签署后对电子签名的任何改动能够被发现；	电子签名及证书由第三方CA进行认证、通过密码算法保证签名改动能够被发现
（四）签署后对数据电文内容和形式的任何改动能够被发现。	对文档的杂凑（Hash）的签名，保证文档的内容和形式的任何改动被发现

“点击即签名”、“你画我签名” 法律上无效



从docusign学来的云签名，不符合中国法律要求：

无数用户在平台上点击确认或勾画笔迹，全部用一张 平台服务器端证书 完成签名，签名私钥不由签名人**专有和控制**，不满足可靠电子签名法律要求。

移动互联网时代，可靠电子签名面临的挑战



中国互联网安全大会



360互联网安全中心



Smartcard



USBKey



交互式USBKey

昂贵的
拥有成本

复杂的
集成使用

独立的
信任孤岛



移动互联网时代，可靠电子签名面临的挑战



Smartcard



USBKey



交互式USBKey

PC环境下的数字证书硬件介质无法迁移到移动互联网；
文件证书无法**合规和安全**的在移动设备中使用；

如何能拥有良好的用户体验，同时签出具有法律效力的可靠电子签名？



基于云的可靠电子签名服务是解决方案



中国互联网安全大会



360互联网安全中心

可靠电子签名云服务

随时、随地、随签



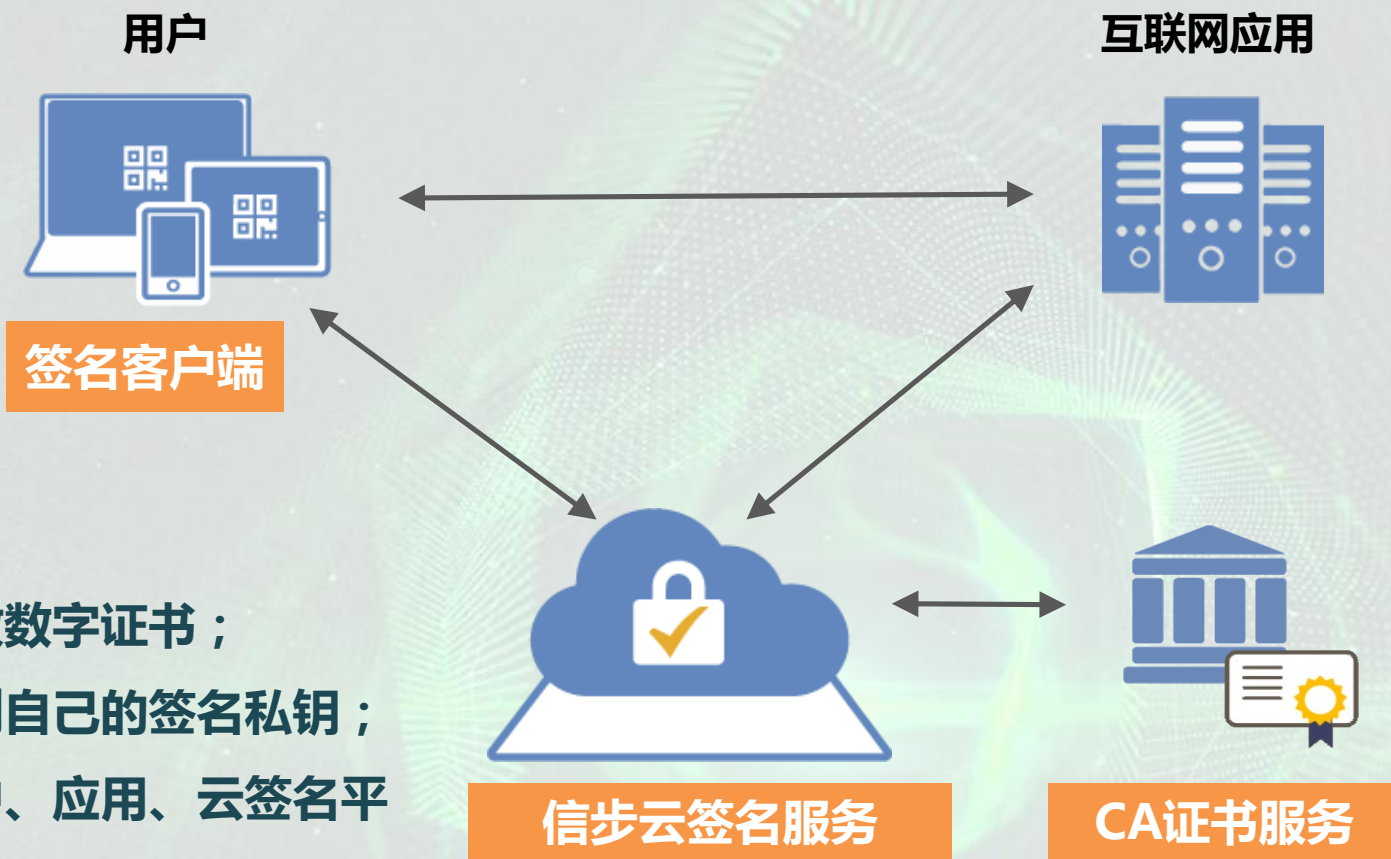
在安全和合规的前提下，用户不需要任何硬件介质，实现可靠电子签名

- 移动终端作为签名设备，利用终端与云服务的互动，实现应用签名
- 用户端零介质成本，发挥移动终端的方便性，随时随地随签
- 基于可信第三方CA数字证书，符合法律要求的可靠电子签名



基于手机的电子签名解决方案
可靠电子签名从此简单

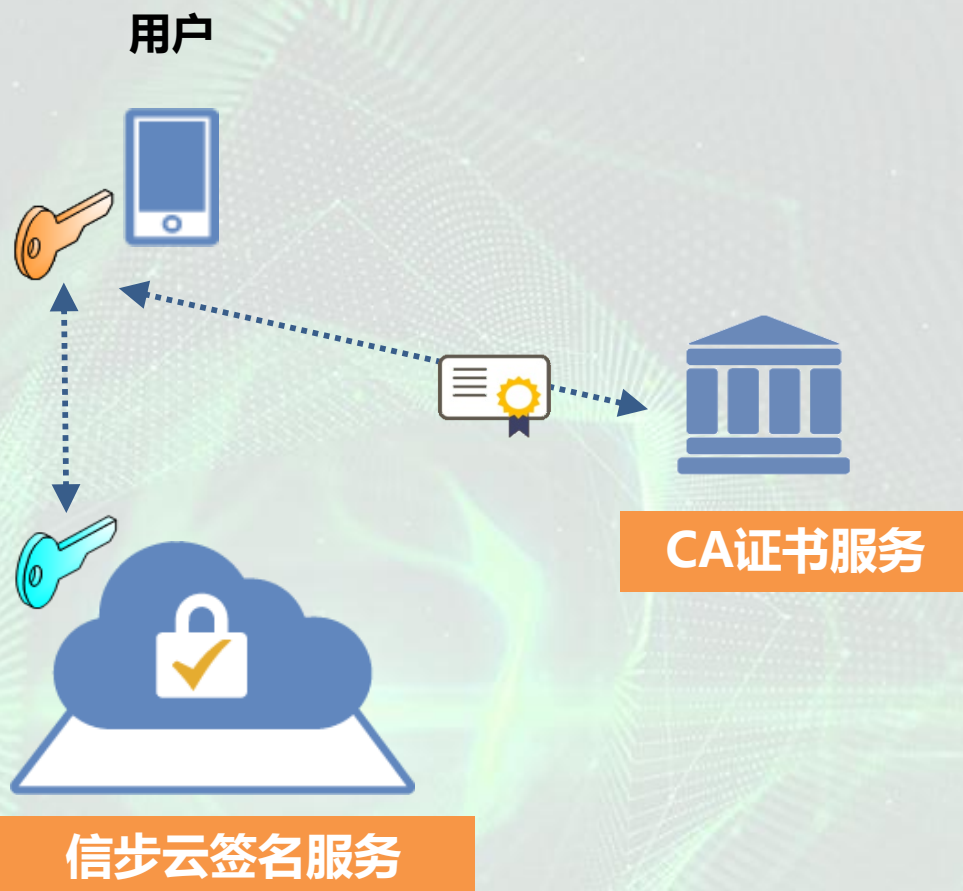
可靠电子签名云服务的系统架构



- 为每个用户发放数字证书；
- 用户拥有并控制自己的签名私钥；
- 每次签名由用户、应用、云签名平台共同完成。

关键技术之一：基于门限分割的密钥管理

用户的密钥由服务端密钥因子和客户端密钥因子组成
客户端、服务端各自保存自身私钥因子，传输公钥因子来合成公钥
CA中心根据组合的公钥，发放证书



关键技术之二：基于多方协同计算的数字签名

- 客户端、服务端分别使用自身存储的密钥因子，单独进行签名操作，形成中间结果
- 客户端合成签名结果，在网络上传输的数据仅包含签名中间结果，无法推算任何密钥信息
- 签名结果使用用户公钥证书进行签名验证



关键技术之三：基于业务的数字签名风险管控

- 应用安全可靠的接入云签名平台
- 云签名服务的签名请求来自应用，客户端无法发起业务无关的签名请求
- 云签名平台根据业务风险要求，对手机终端进行风险控制，在出现较大行为风险时，随时冻结用户密钥，避免用户密钥非法使用的风险



“云、管、端”结合的安全体系

在云签名体系中，只有：

- 知道特定秘密的人（最终用户）
- 使用特定的设备（手机）
- 正确的使用云签名服务（身份认证）
- 对合适的数据（业务要求签名的数据）

才能完成数字签名



安全风险分析：“软证书”无法应对的攻击

一、

以恢复用户密钥为目的的攻击



二、

以非法调用用户密钥为目的的攻击



三、

以绕过认证机制为目的的攻击



安全风险分析：“信步云”应对攻击风险（1）

一、

以恢复用户密钥为目的的攻击



二、

以非法调用用户密钥为目的的攻击

三、

以绕过认证机制为目的的攻击

- 完整的私钥在任何设备和存储中都不会出现，也不会出现在内存和密码设备中，无法通过内存分析等方式获得完整的密钥信息；
- 签名过程中密钥因子无须在网络上传递，无法根据网络层获取到的数据恢复出完整密钥；

安全风险分析：“信步云”应对攻击风险（2）

一、

以恢复用户密钥为目的的攻击

二、

以非法调用用户密钥为目的攻击

三、

以绕过认证机制为目的攻击



- 所有签名请求信息来自业务应用，攻击者无法提出与业务无关的签名请求；
- 对于攻击者重试PIN非法使用客户端和云签名服务进行数字签名，云签名服务对超过设定的错误次数的用户进行锁定；

安全风险分析：“信步云”应对攻击风险（3）

一、

以恢复用户密钥为目的的攻击

二、

以非法调用用户密钥为目的的攻击

三、

以绕过认证机制为目的的攻击



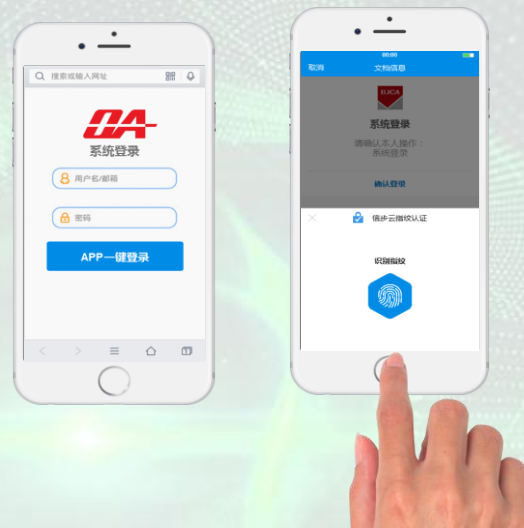
- 客户端认证PIN码是密钥一部分，无法绕过；
- 应用与云签名服务端使用数字证书双向强认证；

广泛的应用场景（1）

各种强身份认证场景



PC端应用/浏览器
登陆认证



手机APP/浏览器
登陆认证

广泛的应用场景（2）

各种数据、文档签名场景



PC应用中数据/文档的签署



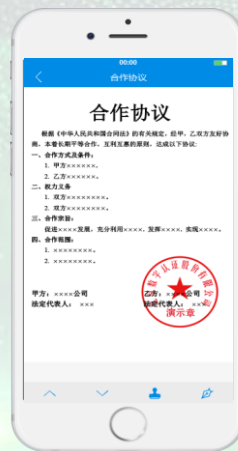
手机推送文档 vs 移动办公流程

广泛的应用场景 (3)

企业云签章场景



云端企业签章管理



移动终端控制云签章

简单易用的可靠电子签名



PIN口令 vs 扫描指纹



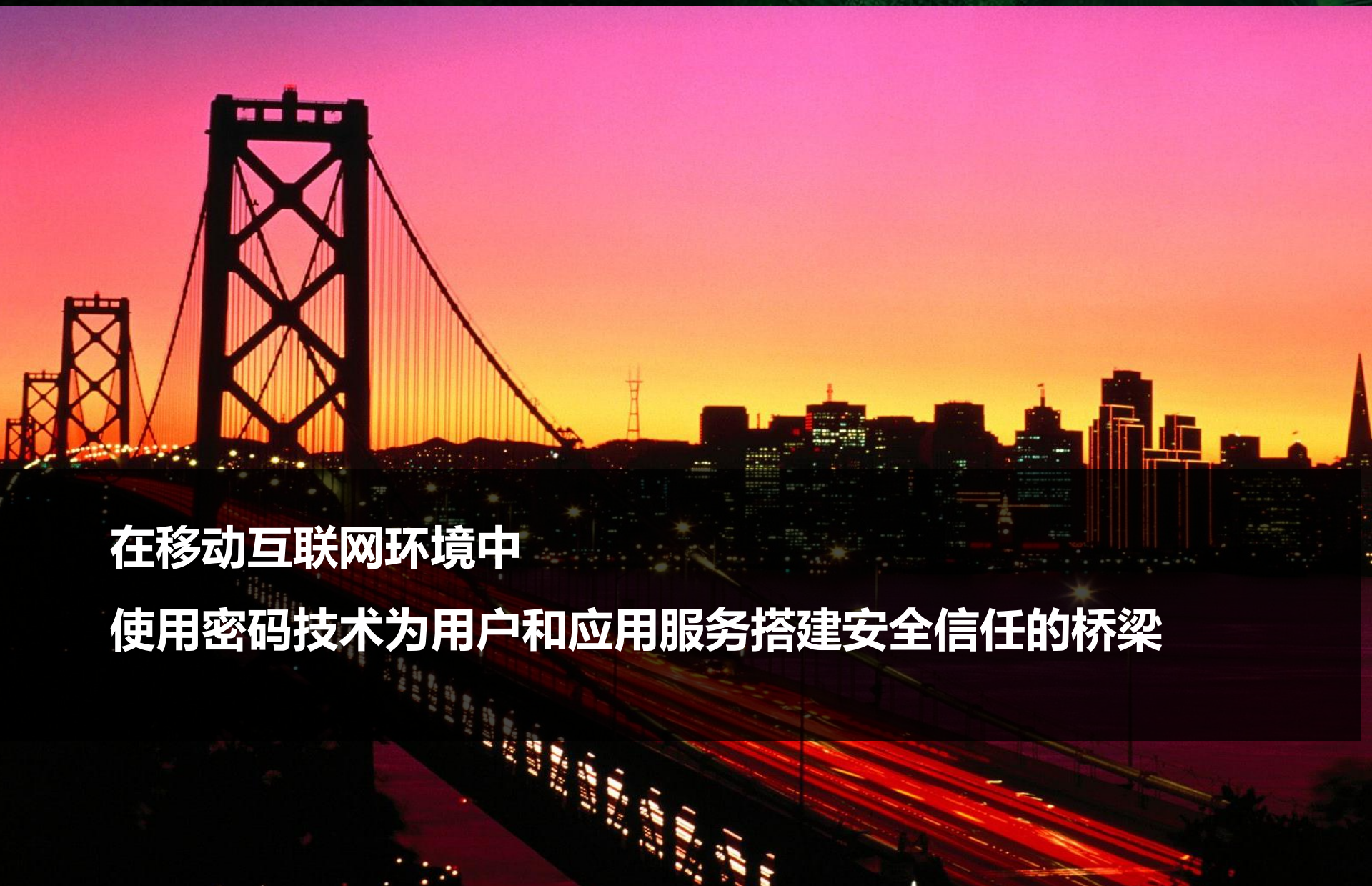
手写笔迹 vs 拍照笔迹

信步云——移动互联网时代的可靠电子签名



- 手机当作“USBKey”，**随时、随地、随签**
- 协同签名专利技术，用户**专有并控制**私钥
- **云、管、端**结合的安全体系，抵御各种攻击风险
- 提供APP及SDK，适用**广泛的**业务应用场景
- 真正安全合规的实现法律要求**可靠电子签名**





在移动互联网环境中
使用密码技术为用户和应用服务搭建安全信任的桥梁

谢 谢



中国互联网安全大会



360互联网安全中心